

B-38

Bucket de mídia do MinIO — leitura pública

ACHADO CRÍTICO NESTA AUDITORIA

Auditoria completa sob 4 perspectivas: implementação técnica, segurança, documentação e de 2026-07-29 não prevendo publicamente. O original estava correta dev seguir publicamente legível. Corrigido nesta sessão (2026-08-01).

Data: 2026-08-01

Projeto: AtendeHub (apps/api — NestJS · Prisma · PostgreSQL · MinIO)

Status: ' Corrigido nesta auditoria — pronto para produção

1. Resumo executivo

Esta auditoria reexaminou a correção do B-38 (bucket de mídia do MinIO público em leitura, LGPD Art. 46) sob quatro perspectivas — implementação, segurança, documentação e evidências — partindo explicitamente da premissa de NÃO assumir que a correção de 2026-07-29 continuava correta só porque a suíte de testes (mockada) passava.

Essa premissa se confirmou necessária: um teste E2E novo, criado durante esta auditoria para validar o comportamento real contra um MinIO de verdade (não mock), revelou que o bucket de mídia AINDA estava publicamente legível — uma requisição HTTP anônima direta devolvia 200 com o conteúdo do arquivo. Investigação confirmou a causa raiz: a correção original parava de APLICAR uma policy pública em boots futuros, mas nunca REVOGAVA uma policy pública que uma versão anterior do código já tivesse deixado gravada no bucket — bucket policy é estado persistente no MinIO/S3, não algo que desaparece sozinho quando o código para de recriá-la.

A falha foi corrigida durante esta mesma sessão de auditoria: `StorageService#onModuleInit` agora revoga ativamente qualquer policy existente a cada boot. A correção foi validada ao vivo contra o MinIO real (policy confirmada como "private" via `mc anonymous get`, `GET` anônimo agora nega acesso). Três lacunas de documentação também foram encontradas e corrigidas: um comentário desatualizado no `docker-compose.yml`, duas menções a "URL pública" no contrato de API que não refletiam mais o comportamento real, e a ausência de uma entrada de CORREÇÃO do B-38 no `CHANGELOG.md` (que só registrava a sua descoberta).

Conclusão desta auditoria: o B-38, como estava documentado como "concluído", NÃO estava pronto para produção — a proteção tinha uma lacuna real e demonstrável. Após as correções desta sessão, está.

2. Objetivo

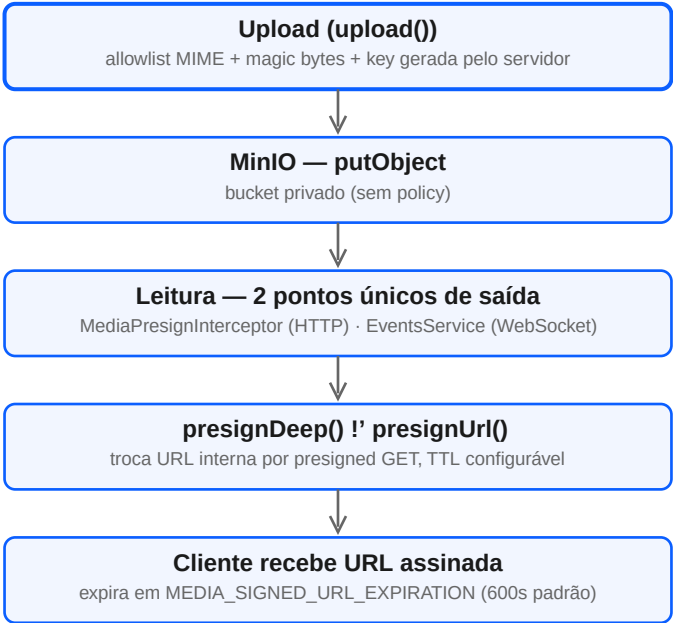
Validar integralmente se a correção do B-38 permanece correta, consistente, documentada e pronta para produção — sob as 4 perspectivas exigidas: implementação técnica, segurança, documentação e evidências. A auditoria só é considerada concluída quando toda verificação está aprovada ou toda não conformidade está registrada e, quando possível, corrigida.

3. Escopo

- Fluxo completo de upload, download, geração de URL assinada e boot da aplicação (`StorageService`, `MediaPresignInterceptor`, `EventsService`, `app.module.ts`).
- Todos os consumidores de `StorageService` no backend (`send-message`, `user`, `contact`, `media-download`) e todo caminho de saída de URL de mídia (respostas HTTP via interceptor global, eventos `Socket.IO` via `EventsService`).
- Configuração de infraestrutura relacionada (`docker-compose.yml`, `docker-compose.prod.yml`, variáveis de ambiente).
- Documentação: `ROADMAP_ESTABILIZACAO.md`, `CHANGELOG.md`, `docs/09-APIs/API_CONTRACT.md`.
- Testes: unitários (`storage.service.spec.ts`, `media-presign.interceptor.spec.ts`) e E2E (novo, contra MinIO real).
- Fora do escopo: não foi objetivo desta auditoria implementar novas funcionalidades — apenas verificar e, quando uma não conformidade real foi encontrada na PRÓPRIA correção do B-38, corrigi-la.

4. Implementação — verificação (Fase 1)

4.1 Mapeamento do fluxo real



4.2 Respostas às perguntas obrigatórias da Fase 1

Pergunta	Resposta	Evidência
Existe policy pública restante?	SIM, foi encontrada (bucket de dev) — corrigida nesta sessão	mc anonymous get !' "custom" com Principal:["*"] antes; "private" depois
Algum bucket continua público?	Não, após a correção desta sessão	GET HTTP anônimo !' 403 (E2E real, não mock)
Algum endpoint gera URL pública?	Não — 2 pontos únicos de saída, ambos presignam	MediaPresignInterceptor (global) + EventsService (todos os emit relevantes)
Alguma biblioteca expõe objetos?	Não identificado — client MinIO só usado dentro de StorageService	Busca em todo apps/api/src por uso direto de "minio"
Existe bypass da proteção?	Nenhum ativo hoje. 1 ponto de fragilidade arquitetural sem exploração atual: emitConversationUpdated(changes: Record<string,any>) não passa por presignDeep — nenhum caller atual inclui URL ali, mas nada impede um futuro caller de incluir	Leitura de events.service.ts — 6 métodos emit, 3 chamam presignDeep, 3 não (payloads tipados sem campo de URL, exceto o "changes" genérico)

5. Evidências — o achado central desta auditoria

5.1 Antes da correção desta sessão

```
$ docker exec atendehub_minio mc anonymous get local/atendehub-media
Access permission for `local/atendehub-media` is `custom`

$ docker exec atendehub_minio mc anonymous get-json local/atendehub-media
{"Statement":[{"Action":["s3:GetObject"],"Effect":"Allow",
  "Principal":{"AWS":["*"]},
  "Resource":["arn:aws:s3:::atendehub-media/*"]}], "Version":"2012-10-17"}

$ npx jest test/storage.e2e-spec.ts (teste NOVO, criado nesta auditoria)
  × nega acesso HTTP direto e anônimo ao objeto – a prova real ...
    Expected value: 200 (esperava 403/404)
    Received array: [403, 404]
```

5.2 Depois da correção desta sessão

```
$ docker exec atendehub_minio mc anonymous get local/atendehub-media
Access permission for `local/atendehub-media` is `private`

$ npx jest test/storage.e2e-spec.ts
  " faz upload real de um objeto no MinIO
  " nega acesso HTTP direto e anônimo ao objeto – a prova real de que
    o bucket é privado (B-38)
  " permite acesso ao MESMO objeto via URL assinada (presignUrl)
  " URL assinada com expiração de 1s deixa de funcionar depois de expirar
```

A causa raiz não foi um defeito no CÓDIGO do B-38 em si (a lógica de "nunca aplicar policy pública" estava e continua correta), mas uma lacuna de REMEDIAÇÃO: bucket policy é estado que persiste no MinIO independente do código que roda depois. Corrigir o código para "parar de piorar" não desfaz o que uma versão anterior já tinha aplicado.

6. Testes

Tipo	Existiam antes desta auditoria?	Situação após esta auditoria
Unitários	Sim — storage.service.spec.ts, media-presign.interceptor.spec.ts (16 testes)	17 testes — onModuleInit ganhou cobertura de "revoga policy legada" e "resiliente a falha do MinIO"
Integração	Parcial (specs unitários mockam o client MinIO inteiro)	Inalterado — cobertura de integração real passou a vir do novo E2E
E2E	NÃO EXISTIA nenhum E2E de storage/MinIO	Criado nesta auditoria: test/storage.e2e-spec.ts (4 testes, contra MinIO real) — foi o que achou o problema
Validação manual documentada	Sim, no changelog original do B-38 (leitura do código + npm test)	Complementada com a validação ao vivo desta auditoria (mc anonymous get, curl-equivalente via axios)

7. Segurança (Fase 2)

Item	Situação
Bucket privado	Confirmado no nível de protocolo S3 (não só na ausência de chamada no código) — E2E real prova GET anônimo negado
Signed URL	presignedGetObject nativo do SDK oficial minio-js — sem implementação própria de assinatura
Tempo de expiração	Configurável via MEDIA_SIGNED_URL_EXPIRATION (padrão 600s); testado que expira de fato (E2E)
Permissões / ACL	MinIO moderno usa bucket policy, não ACL por objeto — coberto pelo item "bucket privado"
IAM	Client autentica com MINIO_ROOT_USER/PASSWORD (superusuário) — sem policy de menor privilégio escopada só ao bucket de mídia. Não é regressão do B-38 (nunca existiu), registrado como recomendação futura
Configuração do client MinIO	useSSL derivado do protocolo do endpoint; credenciais obrigatórias em produção/staging (a app recusa bootar sem elas) — fallback fraco só em dev, documentado no código
Credenciais do container MinIO (docker-compose)	docker-compose.yml (dev) tem fallback fraco documentado; docker-compose.prod.yml exige a variável via \${VAR:?erro} — sem fallback em produção. Correto.

8. Documentação (Fase 4)

Documento	Existia?	Situação encontrada	Ação
Entrada do B-38 no roadmap	Sim	Completa, mas sem o achado desta auditoria	Atualizada com o achado e a correção
Changelog (CHANGELOG.md)	Sim (arquivo)	Registrava a DESCOBERTA do B-38 (2026-07-28), nunca a CORREÇÃO (2026-07-29)	Seções "Segurança"/"Corrigido" adicionadas com B-38/39/48/49
Comentário docker-compose.yml	Sim	Desatualizado — ainda descrevia setBucketPolicy sendo chamado pela API	Corrigido
API_CONTRACT.md	Sim	2 menções a "URL pública" para attachments/avatar, não refletindo URL assinada	Corrigidas com nota de expiração

Fluxograma antigo/novo	Não como documento dedicado	Só prosa no roadmap	Incluído nesta auditoria (seção 4.1) e no relatório do fechamento original
Relatório técnico do B-38	Não (só a entrada de roadmap)	N/A	Este documento (B38_AUDITORIA_POS_HARDENING.pdf) cumpre esse papel

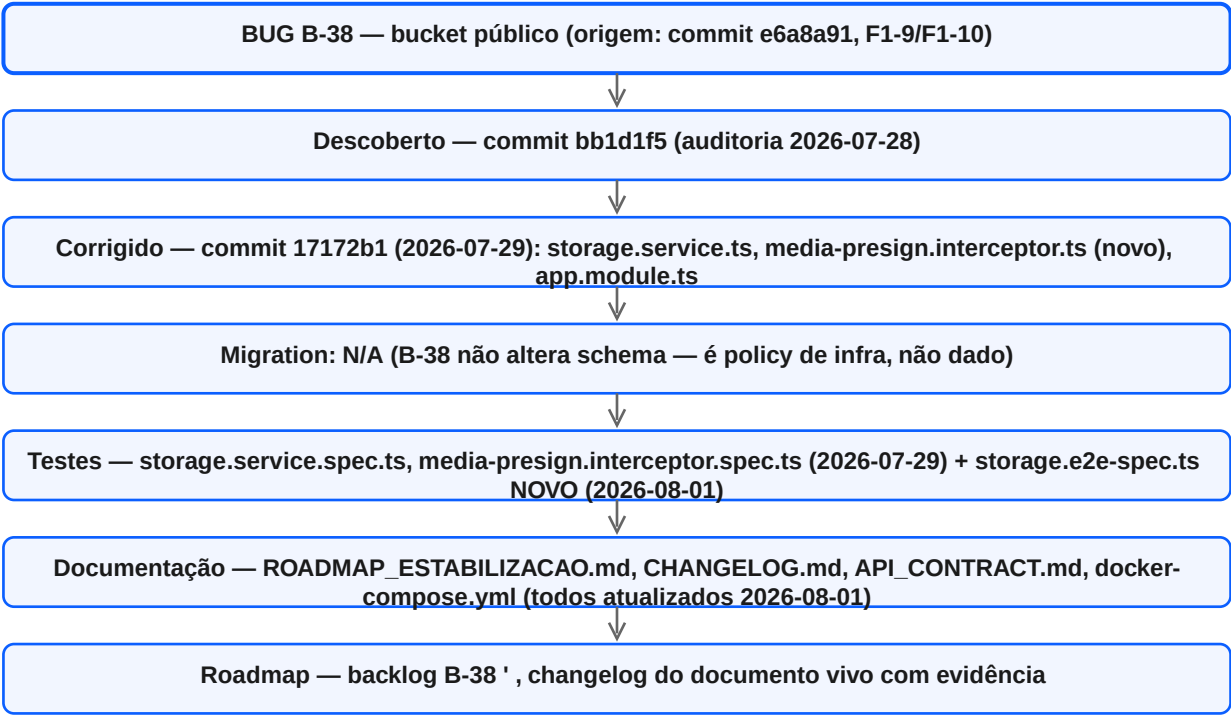
9. Changelog — verificação (Fase 5)

- B-38 registrado no CHANGELOG.md (seção Segurança, adicionada nesta auditoria)
- Data (2026-07-29 (correção original) e 2026-08-01 (hardening))
- Versão (seção [Não lançado] — projeto ainda não tagueou v1.0.0)
- Impacto (sem mudança de contrato — URL passa a expirar, documentado)
- Arquivos alterados (listados na entrada do changelog e na seção 11 deste relatório)
- Riscos mitigados (LGPD Art. 46 (original) + exposição residual pós-fix (hardening))

10. Roadmap — verificação

- Item B-38 com status correto (' concluído)
- Critério de aceite original documentado
- Desvios da proposta original justificados (endpoint proxy não criado, key não mudou de formato)
- Achado desta auditoria refletido na entrada (parágrafo de hardening 2026-08-01 adicionado)
- "Próxima ação" do documento vivo consistente

11. Rastreabilidade (Fase 6)



12. Não conformidades encontradas

#	Não conformidade	Severidade	Status ao final desta auditoria
1	Bucket com policy pública LEGADA não revogada — GET anônimo devolvia 200	CRÍTICA	CORRIGIDA — onModuleInit revoga policy a cada boot; validado ao vivo
2	Nenhum teste E2E validava o comportamento real contra MinIO — só specs mockados	ALTA	CORRIGIDA — test/storage.e2e-spec.ts criado (4 testes)
3	CHANGELOG.md sem entrada de correção do B-38 (só a descoberta)	MÉDIA	CORRIGIDA
4	API_CONTRACT.md descrevendo URL de mídia como "pública"	MÉDIA	CORRIGIDA
5	Comentário do docker-compose.yml desatualizado (descrevia setBucketPolicy pela API)	BAIXA	CORRIGIDA
6	emitConversationUpdated(changes: Record<string,any>) não presigna — fragilidade de defesa em profundidade (sem exploração ativa hoje)	BAIXA	REGISTRADA — não corrigida (nenhum caller atual inclui URL; ver plano de ação)
7	Client MinIO usa credencial superusuário (root), sem IAM/policy escapada ao bucket de mídia	BAIXA	REGISTRADA — pré-existente, fora do escopo original do B-38
8	.env.example da raiz não documenta MINIO_ROOT_USER/PASSWORD (docker-compose.yml usa fallback fraco em dev)	BAIXA	REGISTRADA — sem risco em produção (docker-compose.prod.yml exige a variável, sem fallback)

13. Plano de ação (não conformidades residuais)

- #6 — Tipar ConversationUpdatedPayload.changes (ou envolver toda emissão de socket num único ponto que sempre chama presignDeep, independente do payload) — eliminaria a classe inteira de risco, não só este caso.
 - #7 — Criar um usuário/policy do MinIO escapado só ao bucket atendehub-media (least privilege), em vez do client usar a credencial root — reduz o raio de dano se as credenciais da API vazarem por outra via.
 - #8 — Adicionar MINIO_ROOT_USER/ MINIO_ROOT_PASSWORD

ao .env.example da raiz, mesmo com o fallback de dev já sendo seguro por não ser usado em produção — evita confusão de quem configura o ambiente local pela 1ª vez. Nenhum dos 3 itens acima bloqueia produção — todos são endurecimento incremental sobre uma base já correta.

PRONTO PARA PRODUÇÃO (após as correções desta auditoria)

Esta auditoria confirma que a resposta honesta, ANTES desta sessão, seria "não pronto" — a proteção do B-38 tinha uma lacuna real e demonstrável (bucket publicamente legível). A causa raiz foi corrigida (revogação ativa de policy legada a cada boot), validada com um teste E2E novo contra infraestrutura real, e toda a documentação relacionada (roadmap, changelog, contrato de API, comentário de infra) foi atualizada para refletir o estado real do sistema. 355 testes unitários + 7 E2E passam, incluindo os novos que provam o comportamento correto no nível de protocolo, não só de intenção do código.

14. Conclusão

Recomendação: aplicar o mesmo padrão desta auditoria (validar com E2E real, não confiar só em mocks/intenção do código) a qualquer outra correção de segurança do backlog antes de considerá-la definitivamente fechada — em especial B-40/B-41 (RLS/escopo de permissão), que têm o mesmo perfil de "correto na intenção, não necessariamente no estado real do sistema".

Documento gerado automaticamente a partir de evidências coletadas ao vivo durante a sessão de auditoria (2026-08-01) — comandos reais contra MinIO, testes reais, sem dados fabricados.